

Nathaniel Abera

July 30, 2026

Information Systems Security

A. Containment was the first action the organization took after the IDS detected some unusual outbound traffic at 09:52 on June 24. The machine that was affected was isolated at 10:07 from the network. This containment was done in conjunction with the Containment, Eradication, and Recovery phase as detailed in NIST SP 800-61 Rev. 2 (Cichonski et al., 2012), and this blocked the direct path to the command-and-control address. However, the containment was barely effective. The IDS log records lateral movement over SMB from 10.1.1.45 to 10.1.2.10 at 10:45. This happened after the machine was marked as isolated, so the isolation must have been too late or not completely applied to prevent the malware from spreading out of the HR subnet and into the Finance subnet.

The eradication was the second action which was taken, after the malware was identified at 11:25 as the GhostX RAT. After this detection, antivirus definitions were updated on all of the network's endpoints by 08:30 during the following morning. This was the step of the eradication that was done. It aligns with the steps of the Containment, Eradication, and Recovery phase as detailed in NIST SP 800-61 Rev. 2 (Cichonski et al., 2012). The response that was done is considered to be an effective strategy once the culprit was discovered to be the GhostX RAT. However, the procedure was not able to be as effective because it only begins to activate antivirus and antimalware tools once a threat is discovered. The reason this approach lacks concrete effectiveness is because it relies on the signature. The IDS log also correlates with this statement, as it recorded a suspicious DNS query at 08:02 on June 25 from the 10.1.1.45 address to a known malicious domain. This indicates that a host was still doing malicious activity in the morning after the endpoint had supposedly been restored.

The third action that was taken within the organization was recovery. At 13:45 an antivirus scan began and was done across the entire HR subnet, and the endpoint was also restored from a previous backup. This procedure matches with the NIST SP 800-61 Rev. 2 (Cichonski et al., 2012) framework as it aligns with the Containment, Eradication, and Recovery phase. However,

although the machine was returned to service the same day, the recovery was limited. The procedure is done to restore the systems from the most recent backup point. This introduces a risk of reintroducing the malware to the system again. For example, if the backup was made after 09:14 then the system would most likely be infected again after the backup restoration point is complete because the backup still contains the malware. At 08:02 the next morning the organization had received an alert, but there were no steps within the process which would have been able to catch this malicious activity before the incident was resolved.

The two improvements that would strengthen any future responses to incidents would be implementing automated containment and a post-incident review conducted after every incident. For the automated containment, the organization would contain a host as soon as the IDS raises an alert, isolating that host at both the switch and firewall level. This would drastically reduce the chances of spread of any attacks. This automated isolation would only take seconds rather than minutes to effectively block protocols that will spread. As for the post-incident review, this will ensure proper procedures were completed successfully and they will be done every time an incident happens within any department, not only when multiple departments are affected. As stated in the artifacts, a review was conducted on June 25, but only because there was malware that had reached into a second department. As the current policy states, an incident contained within a single department will receive no formal debrief at all. This new implementation of mandatory reviews aligns perfectly with the Post-Incident Activity phase detailed in the NIST SP 800-61 Rev. 2 (Cichonski et al., 2012). It would require the organization to conduct and document a proper review after all incidents occur to improve future containment and detection procedures.

B. The first vulnerability is the absence of segmentation within the network. The diagram of the network shows that the mail server and the public-facing web server are placed behind the same firewall as the HR and Finance internal network, and these subnets are sharing the same single switch. There is no demilitarized zone (DMZ) separating the internal systems from the public ones. This design leaves the network exposed. The IDS had logged and recorded lateral movement which was sent directly over to SMB from 10.1.1.45 to 10.1.2.10 at 10:45. The best remediation for this vulnerability is to restructure the network by adding a DMZ that separates

the public servers from the internal network, and to place the HR and Finance networks on separate VLANs with filtered inter-subnet traffic. By segmenting a compromised host, this resists lateral movement and also allows for the Finance and HR team to protect its confidentiality and integrity of data and systems, while the DMZ protects its own system and prevents public servers from gaining any access inwards.

The second vulnerability is a weak firewall policy. Rule 102 allows any source, including external hosts, to reach internal networks on any port, which has permitted the external host 162.155.10.102 to be able to scan another internal address 10.1.2.4 at 10:14 based on the logs. Rule 103 allows any traffic going out to reach any external destination on any port, such as when the GhostX RAT had created a command-and-control communication line with 45.33.122.88 at 09:50 based on the logs. The best approach to remediate this is by replacing these rules with stricter least-privileges set rules that will deny any inbound traffic coming from outside sources by default and only give permission of access to specific required services while also applying filtering restrictions of outbound traffic to only approved destinations, addresses, and ports. Restrictions of inbound access allow the prevention of any unauthorized access, protecting the company's confidentiality of internal hosts by allowing them to be discreet from the internet, while the filtering resists and helps detect command-and-control activity and exfiltration of data. This will protect the overall confidentiality and integrity of all information leaving the network.

The third vulnerability is that the firewall management interface is completely exposed. Rule 104 gives permission for any source to be able to access the console of the firewall on port 8080 which leaves the admin interface that controls the security policy exposed and accessible to any host on the internet. The best remediation for this would be to add a restriction to Rule 104 that leaves the console to only be accessible from a dedicated management network or a small set of named administrator addresses, and only over encrypted protocols such as SSH or HTTPS instead of the plain port 8080. By doing this, the organization limits who can gain access to the console and stops attacks aimed at the security control system. This protects both the integrity and configuration of the firewall because there are no parties that are unauthorized that can change the rules that are set in place for the network's defenses. This will protect access into the firewall and prevent attackers from being able to disable the firewall.

C. The first weakness discovered lay in Rule 101 within the firewall, as it allows any source to be able to reach the email server on port 25 without any filtering in between preventing this from happening. Because all the inbound mail is directly accepted from any external senders, attackers can send any potential malicious attachments to users, and they will land in employee inboxes without them being scanned or sandboxed. This is exactly how an incident had emerged at 09:12 on June 24, when an employee in the HR department had received a phishing email which had contained an attachment that had a PDF disguised as a benefit plan update. Shortly after this at 09:14 the attachment was opened and a GhostX RAT was unknowingly installed. This rule had enabled this phishing attempt to be successful because it allowed this compromising scenario to occur. To fix this, rule 101 should be updated by adding a filtering system for any traffic directed to port 25, adding a mail security gateway, and by adding a second rule as well that denies direct SMTP delivery to the email server itself. This way, all documents or attachments will be scanned for suspicious files in a sandbox. This will improve network security by allowing emails to be inspected for any suspicious activity or content instead of relying on an employee to recognize it when they see it.

The second weakness is that the IDS lacks preventive functionality. The IDS rule set operates in detection mode and has no rule that will block specific traffic it identifies under a particular category. Almost every alert within the logs is a notification rather than something seen as a threat. This means that an attacker can keep operating however long they want until a human actually responds. The IDS had flagged an instance of outbound traffic from 10.1.1.45 to 45.33.122.88 at 9:50, and described it as possible GhostX RAT traffic, but the host was left unisolated until 10:07 which had left the channel open for exactly 17 minutes. It had also flagged a port scan that was made at 10:14 from 162.155.10.102, as well as lateral movement over SMB from 10.1.1.45 to 10.1.2.10 at 10:45, without stopping either one. Then at 8:02 the following morning there was also a query of a known malicious domain from 10.1.1.45, which was showing the threat was still active after the endpoint was restored at 13:45. To resolve this problem, the best approach for the organization is to add a prevention rule that drops inline intrusions instead of just alerting on them. This way, any outbound traffic from an internal host that is sent to a destination that is on the threat blocklist will be automatically dropped and it

addresses things such as the command-and-control problem at 45.33.122.88. This will improve the overall network security by switching from detection to enforcement as the mechanism of defense. This will protect the company against the GhostX RAT specifically by derailing its command-and-control channel as soon as the signature matches instead of just waiting on a human to act against it.

References

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide* (NIST Special Publication 800-61 Rev. 2). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-61r2>